



File No.: EXP202213126

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on October 13, 2022. The complaint is directed against CAIXABANK, S.A. with NIF A08663619 (hereinafter, CAIXA). The reasons on which the complaint is based are as follows:

The complainant states that, on March 28, 2022, CAIXA, without her consent, provided her ex-husband "the tax information for 2021 of all my products at Caixabank, of which I am the holder." She states that she became aware of what happened because, subsequently, her ex-husband handed over that documentation to their daughter.

As a result of what occurred, on April 19, 2022, she filed a complaint with CAIXA, receiving confirmation of receipt on April 22, 2022.

On May 13, 2022, she received a response indicating that they were conducting the necessary internal investigations to clarify the events that occurred and, if applicable, to adopt the relevant measures, and that she would receive the corresponding response to her complaint.

However, due to the lack of response, on June 9, 2022, she filed a complaint with the data protection officer of CAIXA (by completing the form provided for this purpose on the entity's website), receiving a response on June 10, 2022.

In that response, she was informed that the complaint must be made by the data subject or by a person with sufficient powers to do so (with their lawyer needing to present a notarized power of attorney).

She states that, on July 11, 2022, she personally delivered, at an office of the respondent, a copy of the powers referred to for the attention of the data protection officer.

Since she did not receive any type of response regarding the outcome of the investigations into a possible breach of the duty of confidentiality, she filed a complaint with this Agency.

Along with the complaint, she submitted:

- A copy of the general power of attorney for litigation and special powers for other faculties, dated July 8, 2022.
- A copy of the documentation related to the disputed tax information.
- A copy of the response from the respondent, dated May 13, 2022, communicating the initiation of the relevant internal investigation actions.
- A copy of the response from the data protection officer, dated June 10, 2022.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGD), the complaint was forwarded to CAIXA for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on December 13, 2022, as evidenced by the acknowledgment of receipt in the file.

On January 16, a written response was received by this Agency indicating: "... In relation to the aforementioned letter and regarding the complaint filed by Ms. A.A.A. (the "Complainant"), in which she states that, on March 28, 2022, the respondent, without her consent, provided her ex-husband "the tax information for 2021 of all my products at Caixabank, of which I am the holder," we must inform you of the following:

- (i) According to our systems, the Complainant and Mr. B.B.B. (ex-husband) were both joint holders of the deposit ***REFERENCE.1, until August 25, 2022, with Mr. B.B.B. being the one listed as the interlocutor for the product.
- (ii) An internal investigation has been conducted regarding the statements made by the Complainant, and it has been determined that on April 8, 2022, the following events occurred:

- Mr. B.B.B. went to the office to obtain the tax information corresponding to the previous year (which CaixaBank makes available to its clients through the "Single Tax Statement").
- From the office, access was made via the client's NIF to the statements of Mr. B.B.B., specifically to the Single Tax Statement of the client's positions at CaixaBank for the year 2021.
- Subsequently, he consulted the movements of the deposit ***REFERENCE.1, jointly owned by Mr. B.B.B. and the Complainant, Ms. A.A.A., and then accessed the Single Tax Statement for the year 2021 corresponding to the Complainant.

As can be seen, in the context of the joint management of the product shared by the marriage formed by the Complainant and Mr. B.B.B., who acted as the interlocutor before the office (and who is now, according to the Complainant, her ex-spouse), the office accessed all the tax information of both holders, incurring a human and involuntary error in delivering the Single Tax Certificate to the Complainant's ex-husband..."

THIRD: On January 13, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/35

FOURTH: On August 21, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the respondent, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR, respectively.

FIFTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the respondent submitted a written statement of allegations requesting the filing of the proceedings, arguing that CAIXABANK's conduct does not constitute any infringement of Article 5.1.f) GDPR or Article 32 GDPR.

SIXTH: On December 20, 2023, a resolution proposal was issued proposing to sanction CAIXABANK, S.A., with NIF A08663619, for an infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR, with a fine of:

- For the infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of that regulation, an administrative fine of €50,000 (FIFTY THOUSAND EUROS)
- For the infringement of Article 32 of the GDPR, classified under Article 83.4.a) of that regulation, an administrative fine of €20,000 (TWENTY THOUSAND EUROS).

SEVENTH: Once the resolution proposal was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the respondent submitted a written statement of allegations in which it requests the filing of the proceedings, arguing that CAIXABANK's conduct does not constitute any infringement of Article 5.1.f) GDPR or Article 32 GDPR.

From the actions taken in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

SOLE: It is established in the file that CAIXA, without the consent of the complainant, provided her ex-husband with the 2021 tax information of all the products of Caixabank, of which she was the holder.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU)

2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Allegations to the initiation agreement

ALLEGATIONS

PRELIMINARY. – "A COMPLAINT ABOUT A SECURITY BREACH DOES NOT IMPLY THE DIRECT IMPOSITION OF A SANCTION"

We find it appropriate to begin these allegations with a literal citation from the initiation agreement itself (Section II, Preliminary Issues):

As the Agency itself indicates, if there is diligence on the part of the responsible party and the appropriate and proportionate security measures, an eventual and accidental event such as the one at hand is not subject to any sanction.

In response to this allegation, this Spanish Agency for Data Protection must emphasize that, as cited in the initiation agreement (Section II, Preliminary Issues):

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data."

5/35

Indeed, the receipt of a complaint regarding a security breach, understood as a violation of personal data security, does not imply the imposition of a sanction; an analysis of the circumstances must be conducted for the purpose of imposing a sanction.

FIRST. – THE OCCURRED EVENT DOES NOT CONSTITUTE A REPORTABLE SECURITY BREACH

We are faced with an incident caused by a person, an employee of the Entity, in relation to certain information owned by the complainant (the Tax Certificate corresponding to the year 2021, which summarizes the income from movable capital), which was made available to her ex-spouse, with the complainant stating that she did not authorize such disclosure.

This is an isolated incident, involving one person and one identified recipient, affecting a very small volume of data, which, in no case, constitutes sensitive data.

Although the complainant has not communicated the damages resulting from the actions of the office staff, any potential consequences would be estimated to have a low level of severity.

According to the previous assessment of the relevant risk factors, conducted in conjunction with the "Guide for the Notification of Personal Data Breaches" published by this Agency, it can only be concluded that the occurred event does not constitute a reportable security breach, neither to the Control Authority nor to the data subject.

In response to this allegation, this Agency must refer to the provisions of Article 5.1 f) of the GDPR, Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."

In this case, it is established that the personal data of the complainant, contained in the CAIXA database, was improperly disclosed to third parties, violating the principle of confidentiality; as the 2021 tax information of all Caixabank products, of which the complainant was the owner, was provided to her ex-husband, who became aware of what had occurred because, subsequently, he handed over

that documentation to their daughter.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/35

The GDPR broadly defines “personal data breaches” as “all security breaches that lead to the accidental or unlawful destruction, loss or alteration of personal data transmitted, stored or otherwise processed, or unauthorized communication or access to such data.”

It is evident that we are dealing with a personal data breach; since there has been unauthorized access to the 2021 tax information of all Caixabank products, of which the complainant was the owner. It is worth noting that this definition is included in the “Guide for the Notification of Personal Data Breaches” published by this Agency.

Having clarified the concept of a personal data breach, it is important to emphasize that, at no time, has the respondent been accused of violating Article 33 of the GDPR or violating Article 34 of the GDPR, which regulates the communication of security breaches to the control authority and to the data subjects, respectively.

SECOND. – ON THE MEASURES TAKEN TO PREVENT SIMILAR EVENTS FROM OCCURRING AND ON THE MEASURES TAKEN TO PREVENT SIMILAR EVENTS FROM OCCURRING

2.1. MEASURES TAKEN TO PREVENT SIMILAR EVENTS FROM OCCURRING

The event subject to this complaint occurred due to actions contrary to internal regulations by an employee of the Entity in an individual and isolated act.

CaixaBank has adopted the appropriate technical and organizational preventive measures aimed at preventing incidents like the one that occurred. To this end, the Entity has implemented a regulatory framework and a training and awareness program for its employees, which includes, among other actions and documents, the following:

- An Ethical Code (Ethical Code and Principles of Action of CaixaBank), which applies to all employees of the Entity, who must be aware of and comply with it, specifically outlining the obligations of employees regarding access to the data and information of the Entity's clients, which includes, among others, the following provisions:

“1. This Code applies to CaixaBank and to all employees, executives, and members of the Governing Bodies of CaixaBank (hereinafter, the “Subject Persons”). All of them must be aware of and comply with this Code.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

7/35

“3.6 Confidentiality We preserve the confidentiality of the information entrusted to us by our shareholders and clients.

1. The confidentiality of information relating to our clients, employees, members of governing bodies and management, suppliers, and shareholders constitutes the fundamental pillar upon which the trust relationship that is the essence of our activity is based.

2. Current regulations and internal rules regarding the processing and confidentiality of personal data and privacy must be respected.

3. CaixaBank maximally protects the personal information of its clients, shareholders, employees, members of its Governing Bodies, or any natural or legal person with whom it interacts. CaixaBank also requires third-party suppliers or those with whom it has a relationship to preserve the confidentiality of the information they may access in connection with the contractual relationship they maintain with CaixaBank.

4. The individuals subject to this obligation will only use the information received from shareholders, clients, suppliers, Governing Bodies, and employees for the purpose for which it was transmitted, all in

accordance with current regulations in this matter. Access to information that is not strictly required for the performance of our work will never be permitted. Before transmitting information to third parties, the individuals subject to this obligation must ensure that they are authorized and that there is a legitimate reason for such transmission. Even in cases where they are authorized, it is necessary to limit the volume of information disclosed to what is strictly necessary. In case of any doubt, they must consult with their hierarchical superior or, depending on the identity of the matter, with the Information Security Department of CaixaBank.”

- An Internal Rule on the processing and confidentiality of client data (Rule 47: Confidentiality and processing of personal data), which specifically addresses the aspect of access to data by employees, which includes, among others, the following provisions:

“2.9. General obligations of CaixaBank employees Employees of CaixaBank are obliged to: •

Safeguard and maintain professional secrecy and the confidentiality of the personal data they process, which implies: o NOT disclosing to third parties any information to which they have access in their capacity as employees and for the performance of the functions assigned to them. o PROHIBITION of any inquiry that is not necessary for the performance of the aforementioned functions and is justified by the operation being carried out. • Use only the corporate tools and applications made available to them by the Entity in their day-to-day activities.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/35

- A protocol for continuous and mandatory training on privacy and data protection to support this regulatory framework. The content of the training conducted by the employee is attached as Document No. 1.

- An implementation of indicators by the Office Network Audit, which, based on indicators of ordinary activity and alerts of activities unrelated to the roles of employees, such as inquiries to clients not assigned to the office or manager's portfolio, relevant individuals, inquiry times, or similar, promotes recurrent investigations into suspicious operations that may not be appropriate for the job performed. In the case at hand regarding this complaint, the fact that the office and employee involved in the incident were the usual ones for the complainant prevented the system of alerts for anomalous activities from detecting the incident before the client's complaint.

- A continuous awareness program through the publication of notes and news on the corporate intranet of the Entity, to remind employees of their obligations regarding confidentiality. An example of the periodic content published is attached.

2.2. MEASURES TAKEN TO PREVENT SIMILAR INCIDENTS

By this Entity, and in light of the events that occurred, two types of measures were adopted:

- Employees of the office have been reminded of the importance of the contents indicated in the previous section 2.1. in their interactions with clients.
- Regarding the employee of the office involved in the incident, the corresponding file has been initiated for this breach of confidentiality.

In accordance with the above, it is proven that CaixaBank diligently applies appropriate technical and organizational measures that ensure the adequate security of its clients' data; however, obviously, the adoption of such measures cannot eliminate a singular incident caused by an employee of the entity, so there is no infringement of Article 5.1.f of the GDPR.

In response to this allegation, we must insist that, indeed, the events that occurred constitute a violation of Article 5.1.f of the GDPR.

Article 5.1.f) “Principles relating to processing” of the GDPR states:

“1. Personal data shall be:

(...)

C/ Jorge Juan, 6

www.aepd.es

f) treaties in such a way as to ensure adequate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ("integrity and confidentiality")."

In the present case, it is established that the personal data of the claimant, contained in CAIXA's database, was improperly disclosed to third parties, violating the principle of confidentiality; as the tax information for 2021 of all the products of Caixabank, of which the claimant was the holder, was provided to her ex-husband, who later handed over this documentation to their daughter.

A different issue is that CAIXA, as the data controller, is obliged to apply appropriate technical and organizational measures to ensure a level of security adequate to the risk presented by the processing of data.

These measures are not only technical measures of the information systems but also organizational measures of the human factor.

The training of employees who have access to or availability of personal data in their databases is an essential control that every diligent organization must ensure and certify.

On the other hand, it should be emphasized that CaixaBank's acknowledgment that it has adopted the appropriate technical and organizational preventive measures to avoid incidents like the one that occurred indicates that the security measures implemented were insufficient or not robust enough.

Finally, claiming that "The event subject to this complaint occurred due to actions contrary to internal rules by an employee of the Entity in an individual and isolated action" does not exempt the organization from responsibility nor justify the non-compliance with current data protection regulations as the data controller.

THIRD. – ON THE ALLEGED INFRINGEMENT OF ARTICLE 32 GDPR

This Entity is in absolute disagreement with this accusation made by the Agency in the Initiation Agreement.

Firstly, we must point out that it seems that this Agency is double-imputing CaixaBank for the same alleged infringement: the alleged lack of adequate or appropriate security measures, which could be incurring a violation of the principles of the sanctioning procedure (specifically, the non bis in idem principle), and, therefore, violating the rights of my represented party.

Secondly, we bring to attention all the aspects already indicated in the previous allegation SECOND, to reiterate that CaixaBank applies appropriate technical and organizational measures to ensure the adequate security of the data it processes.

To this end, we must emphasize that the protocols, procedures, systems, and measures established by CaixaBank are aimed at preventing anyone from accessing information they have no right to know, thus avoiding breaches of confidentiality. A single isolated action ignoring these protocols, procedures, systems, and measures, in the context of the volume of data and information that is managed daily by all employees of CaixaBank, is proof that the protocols, procedures, systems, and measures function appropriately because they are known and applied by the employees of the Entity.

Moreover, we find that this Agency makes an extrapolation from a strictly singular situation to, without conducting any evidentiary activity in this regard, impute to my represented party the non-compliance with the proactive responsibility obligations to which it is subject under data protection regulations.

Indeed, the Initiation Agreement incurs in maximalism by understanding that once a strictly singular event has occurred, this circumstance determines, in the eyes of the Agency, but without evidence to refute it, that my client has not adopted sufficient security measures to preserve the rights of the data subjects and guarantee the confidentiality and integrity of the data.

Thus, the Agency in the Initiation Agreement links the alleged non-compliance with the provisions of Article 32 GDPR with the occurrence of the result that happened as a consequence of a mere and fortuitous human error.

This accusation neither fits nor corresponds to the objective facts that occurred, and is, apart from being excessive, totally contrary to the legal system, as it implies legal uncertainty and null predictability of the applicable legal norms.

In this regard, it is considered necessary to bring to attention a ruling from the Supreme Court dated February 15, 2022 (cassation appeal 7359/2020), where the High Court clearly states that the obligation imposed by Article 32 GDPR to adopt technical and organizational measures aimed at ensuring the confidentiality, availability, and integrity of information is an obligation of means and not of result, as the Agency has traditionally considered and supported by the doctrine of the National Court. "In obligations of means, the commitment undertaken is to adopt the technical and organizational means, as well as to deploy diligent activity in their implementation and use that tends to achieve the expected result with means that...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
11/35

reasonably qualify as suitable and sufficient for their achievement, which is why they are referred to as "diligence" or "behavior" obligations.

The difference lies in the responsibility in each case, as while in the obligation of result one is liable for a harmful outcome due to the failure of the security system, regardless of its cause and the diligence used. In the obligation of means, it is sufficient to establish technically adequate measures and to implement and use them with reasonable diligence. In these latter cases, the sufficiency of the security measures that the responsible party must establish must be related to the state of technology at any given moment and the level of protection required in relation to the personal data processed, but a result is not guaranteed.

As a consequence of all the above, it is the opinion of this party that the premises that underpin the assessment of the circumstances of the case and that lead the Agency to impose the infringement for the alleged violation of Article 32 of the GDPR, fall short in light of the reality of the singular event that occurred and the jurisprudence of the Supreme Court, circumstances that should necessarily lead to the filing of the present sanctioning file.

In response to this allegation, it is evident that CAIXA did not have reasonable security measures in place based on the estimated potential risks, violating what is provided in Article 32 "Security of processing" of the GDPR, which establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probability and severity risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. When assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as a factor..."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
12/35

to demonstrate compliance with the requirements established in paragraph 1 of this article.

4. The data controller and the data processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller, unless required to do so by Union law or the laws of the Member States.”

We insist on the arguments made in response to the previous allegation; CaixaBank, as the data controller, is obliged to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk presented by the data processing.

These measures are not only measures related to information systems but also organizational measures concerning human factors.

Regarding the principle of non bis in idem alleged, the Judgment of the National Court of July 23, 2021 (rec. 1/2017) states that,

“(…) According to the legislation and jurisprudence presented, the principle of non bis in idem prevents punishing the same subject twice for the same act based on the same grounds, understood as the same legal interest protected by the sanctioning norms in question. Indeed, when there is a triple identity of subject, act, and grounds, the sum of sanctions creates a sanction foreign to the proportionality assessment carried out by the legislator and materializes the imposition of a legally unprovided sanction that also violates the principle of proportionality.

However, for "bis in idem" to be applicable, there must be a triple identity between the compared terms: objective (same facts), subjective (against the same subjects), and causal (for the same grounds or reason for punishment):

- a) The subjective identity implies that the affected subject must be the same, regardless of the nature or judicial or administrative authority judging the case and independently of who the accuser or specific body that has resolved is, whether judged alone or in conjunction with other affected parties.
- b) The factual identity implies that the judged facts must be the same, and excludes cases of real concurrence of infractions where there is not a single unlawful act but several.
- c) The identity of grounds or causal identity implies that the sanctioning measures cannot coincide if they respond to the same nature, that is, if they share the same teleological foundation, which occurs between criminal and administrative sanctions, but not between punitive and merely coercive measures.”

Consequently, the principle of non bis in idem has not been violated; since, although broadly understood, the facts are detected as a consequence of a personal data breach, the infringement of Article 5.1.f) of the GDPR is specified in a clear loss of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/35

confidentiality and availability, while the infringement of Article 32 of the GDPR is reduced to the absence and deficiency of the security measures (only security) detected, present regardless of the personal data breach. In fact, if the security measures that CAIXA had implemented had been detected by the AEPD without the loss of confidentiality and availability occurring, it would only have been sanctioned under Article 32 of the GDPR. CAIXA considers that both provisions require a single conduct, which is to implement adequate security. This is not true, since Article 5.1.f) of the GDPR is not limited to ensuring adequate security relative to the risk, but to ensuring integrity and availability. And not only through security measures, but through all types of appropriate technical or organizational measures.

As we have indicated, Article 5.1.f) of the GDPR sanctions a loss of availability and confidentiality only, and Article 32 of the GDPR addresses the absence and deficiency of the security measures implemented by the data controller. Absence or deficiency of security measures, we add, that infringe the GDPR regardless of whether there has been a loss of confidentiality and availability.

Regarding the doubt about whether Article 5.1.f) of the GDPR imposes, like Article 32 of the GDPR, an obligation of means, or whether it is an obligation of result, it should be noted that Article 5.1.f) of the

GDPR incorporates the principle of integrity and confidentiality and determines that personal data shall be processed in such a way as to ensure an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures. It establishes an obligation of result.

On the other hand, Article 32 of the GDPR regulates how the security of processing should be articulated in relation to the specific security measures that must be implemented, so that taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk that includes, among other things, the ability to ensure the confidentiality of the data.

It may occur that the measures are not adequate without there being a loss of integrity and/or confidentiality. This is an obligation of means.

Article 32 of the GDPR imposes on data controllers the obligation to determine and establish appropriate technical and organizational security measures to ensure an adequate level of security relative to the risk based on the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of individuals.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

14/35

In order to maintain the security of the processing, the controller is required to assess the inherent risks of the processing and apply measures to mitigate them. In this risk assessment, the risks that threaten the rights and freedoms of the data subjects must be taken into account, especially their fundamental rights and freedoms.

FOURTH. - ON THE APPLICATION OF AGGRAVATING FACTORS

Sections FIRST and FOURTH of the dispositive part of the Initiation Agreement of this Sanctioning Procedure state (we quote verbatim) that the Director of the AEPD agrees as follows:

“FIRST: TO INITIATE SANCTIONING PROCEDURE against CAIXABANK, S.A., with NIF A08663619, for the alleged infringements of Articles 5.1.f) and 32 of the GDPR, classified, respectively, in Articles 83.5.a) and 83.4.a) of the GDPR. (...)

FOURTH: THAT for the purposes provided for in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be:

- For the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5.a) of that regulation, an administrative fine of 50,000€ (FIFTY THOUSAND EUROS).
- For the alleged infringement of Article 32 of the GDPR, classified in Article 83.4.a) of that regulation, an administrative fine of 20,000€ (TWENTY THOUSAND EUROS).”

The AEPD refers in its FACTUAL BASIS V and VIII, certain concurrent circumstances in the actions of Caixabank, determining that they should be considered as aggravating factors of its responsibility. All this, unilaterally and without having previously heard my client's defense regarding the alleged facts. In the present Sanctioning Procedure, this Agency considers that the following aggravating circumstances are present:

Sanction for the infringement of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the infringement in question is serious for the purposes of the GDPR and that it is appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- b) the intentionality or negligence in the infringement;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/35

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the infringement in question is serious for the purposes of the GDPR and that it is appropriate to graduate the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- b) the intentionality or negligence in the infringement;

My client considers that in the present case there is no infringement of Article 5.1.f GDPR or Article 32 GDPR, so the aggravating factors that this Agency improperly considers to be concurrent would not apply.

In response to this allegation and regarding the aggravating factor applied to the sanctions for the infringements committed, this Spanish Agency for Data Protection reproduces the criterion adopted by the Supreme Court due to the lack of the required diligence.

FIFTH. – CHANGE OF CRITERION IN THE EXERCISE OF THE SANCTIONING POWER

Finally, this Agency in a previous file (EXP 202300974) with the same object, resolved to archive the proceedings on May 9 of this year.

That is to say, in a similar event to the one at hand, where a human and involuntary error is noted, this Agency proceeded to archive the proceedings, indicating that Caixabank has implemented the necessary, proportionate, and adequate measures required by data protection regulations.

The fact that the administrative body changes its interpretation criterion, without any evidentiary activity, and thus adopts measures contrary to those previously taken, constitutes a violation of the principles of Administrative Sanctioning Law, as well as the constitutional guarantees of my represented party, a circumstance that implies the full and radical nullity of the administrative procedure at hand, in the event that this Agency intends to persist in it.

In response to this allegation, it should be emphasized that the aforementioned file does not have the same object; therefore, the archiving of the file at hand is not appropriate.

At that time, CAIXABANK already stated that it had implemented a regulatory framework and a training and awareness program that includes, among other actions and documents, the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/35

- An Ethical Code (Ethical Code and Principles of Action), which applies to all employees of the Entity, who must know and comply with it, specifically outlining the obligations of employees regarding access to customer data and information, the confidentiality of information, and never accessing information that is not strictly required for the performance of their work.

- An Internal Regulation on the treatment and confidentiality of customer data, which specifically addresses the aspect of employee access to data, which includes, among other obligations, the duty to safeguard and maintain professional secrecy and the confidentiality of personal data processed, which implies not disclosing to third parties any information accessed in their capacity as employees and for the performance of their assigned functions, prohibition of any inquiry that is not necessary for the performance of the aforementioned functions and is justified by the ongoing operations, and using only the corporate tools and applications provided by the Entity in their day-to-day activities.

- A protocol for continuous and mandatory training in privacy and data protection to support this regulatory framework.
- An implementation of indicators, by the Office Network Audit, which, based on ordinary activity indicators and alerts of activities not related to the roles of employees, such as inquiries to clients not assigned to the office or manager's portfolio, relevant persons, inquiry times, or similar, promotes recurrent investigations into suspicious operations that may not be appropriate for the job performed. Curiously, the same measures alleged in the present file as measures adopted to prevent similar events from occurring.

Consequently, the insufficiency and weakness of CAIXABANK's technical and organizational security measures appropriate to ensure an adequate level of security concerning the risk in the processing of personal data of its clients is evident.

For all the above reasons, THE ALLEGATIONS PRESENTED WERE DISMISSED.

III

Allegations to the proposed resolution

In response to the allegations presented, according to the order set forth by the entity being claimed against, the following should be noted:

ALLEGATIONS

FIRST. - THE AEPD CANNOT DEDUCE, FROM THE OCCURRENCE OF A SINGULAR EVENT, THAT THE TECHNICAL AND ORGANIZATIONAL MEASURES IMPLEMENTED BY THE RESPONSIBLE PARTY WERE NOT APPROPRIATE.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/35

Indicates the CAIXA the following:

In the previous written allegations, my client began with the following literal citation of the words of the AEPD itself, included in the Initiation Agreement (Section II, Preliminary Issues):

In accordance with such premise, in the written allegations to the Initiation Agreement, submitted to the AEPD on September 11, 2023, CaixaBank proceeded to describe all the technical and organizational measures implemented by CaixaBank that demonstrate and prove that these are appropriate measures to prevent unauthorized communication as occurred in the procedure at hand, which we reiterate, although already extensively detailed in our previous writing, to which we appropriately refer:

(i)

Technical measures

- Access of managing personnel only to the data of clients from the client portfolio of their office.
- Implementation of indicators and alerts by Internal Audit aimed at detecting activities of managing personnel not related to their roles and/or with their managed clients.

(ii)

Organizational measures

- Regulatory framework of mandatory compliance for all employees at CaixaBank, consisting of (i) an Ethical Code and Principles of Action of CaixaBank, and also (ii) Standard 47 (Confidentiality and Processing of Personal Data).
- Any infringement of the provisions of the aforementioned regulatory framework is subject to the initiation of a disciplinary file, which may lead to the imposition of sanctions ranging from suspension of employment and salary to dismissal of the employee.
- Training program on personal data protection affecting Bonus (i.e., those employees who do not complete or pass the course do not receive this variable remuneration).
- Ongoing awareness program regarding the processing of personal data of our clients.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

As can be seen, CaixaBank, in its capacity as a diligent data controller, has demonstrated that it has implemented multiple and diverse appropriate technical and organizational measures aimed at:

(i) preventing and avoiding that its employees carry out processing operations that do not comply with the GDPR, and

(ii) ensuring that the processing of its clients' data is carried out in accordance with the principles of Article 5 of the GDPR.

In contrast, this Agency, in its proposed resolution, does not examine or assess the substance of the measures (neither in relation to their nature, nor concerning their content, nor to their manner of application), limiting itself to "insisting on the contested facts" (page 11/23) or the simple statement "it is evident that the CAIXA did not have reasonable security measures" (page 12/23).

This need for objective examination or assessment is not a requirement of my client, but is expressly demanded by the recent jurisprudence of the Court of Justice of the European Union, which in its Judgment in Case C-340/21 (Natsionalna agentsia za prihodite, delivered on December 14, 2023) states the following:

"45 Therefore, to control the appropriateness of the technical and organizational measures adapted pursuant to Article 32 of the GDPR, a national court must not limit itself to verifying how the data controller has sought to comply with the obligations incumbent upon it under that article, but must carry out an examination of the substance of these measures, in light of all the criteria referred to in that article, as well as the specific circumstances of the case and the evidence available to the court.

46 Such an examination requires a concrete analysis of both the nature and content of the measures adopted by the data controller, the manner in which those measures have been applied, and their practical effects on the level of security that it was obliged to guarantee, taking into account the inherent risks of that processing."

That is to say, the Agency cannot limit itself to stating, without further ado (page 8/23 of the Proposed Resolution document), that "we must insist that the events that occurred constitute a violation of Article 5.1.f GDPR," or that "the CAIXA did not have reasonable security measures" (page 11/23), without making any objective assessment or argumentation regarding the multiple and diverse measures implemented by my client.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

This fact constitutes a flagrant violation of the fundamental right to effective judicial protection and, consequently, taints the present administrative procedure with absolute nullity.

For all the above reasons, my client can only conclude in the same sense as the Judgment of the CJEU previously cited:

1. That there has been no infringement of Article 5.1.f of the GDPR because the GDPR does not require infallibility, but rather the adoption of appropriate measures to ensure the adequate protection of personal data processed by the controller. The provision for the adoption of measures regulated by the GDPR would be meaningless if the requirement imposed on the controller by the GDPR consisted simply of preventing any infringement:

"50 In particular, the data controller must, in accordance with the principles of integrity and confidentiality of personal data established in Article 5, paragraph 1, letter f, of that Regulation, ensure that such data is processed in a manner that guarantees an adequate level of security for personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures and must be able to demonstrate compliance with the aforementioned principles."

2. That the AEPD cannot claim that the technical and organizational measures implemented by the controller are not appropriate simply because the reported incident occurred, without any evidentiary

assessment of the aforementioned measures:

“39 (...) Articles 24 and 32 of the GDPR must be interpreted in the sense that a communication of authorized personal data or unauthorized access to such data by ‘third parties’ for the purposes of Article 4, point 10, of the aforementioned Regulation, are not sufficient on their own to consider that the technical and organizational measures adopted by the data controller were not ‘appropriate’ under the aforementioned Articles 24 and 32.”

In response to this allegation, this Agency must remind that technical and organizational measures must be adopted, implemented by the data controller, and followed by the personnel providing services within the organization.

In the present case, it is not only established that the technical and organizational measures imposed by the data controller could have been breached by an employee of the organization acting negligently, but it has also been demonstrated a lack of appropriate measures, as the measures adopted must be effective to ensure compliance with the GDPR, which must be assessed on a case-by-case basis.

Appropriate measures must be adopted taking into account the risks to the rights and freedoms of the data subjects, which will include the approval of protocols, policies, and decision-making, but it will also be necessary to adopt technical measures that mitigate the risk.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/35

As the CJEU reasons in the cited judgment: “27. The entire Regulation is based on the prevention of risk and the proactive responsibility of the data controller and, therefore, on a teleological approach that seeks the best possible outcome in terms of effectiveness, that is, far removed from the formalistic logic linked to the mere obligation to comply with specific procedures that exempt from liability. (11)”

In this regard, Recital 74 of the GDPR states that “The responsibility of the data controller for any processing of personal data carried out by them or on their behalf must be established. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with the General Data Protection Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons.”

Recital 76 adds that “The likelihood and severity of the risk to the rights and freedoms of the data subject must be determined with reference to the nature, scope, context, and purposes of the data processing. The risk must be assessed based on an objective evaluation through which it is determined whether the data processing operations pose a risk or whether the risk is high.”

In the case at hand, CaixaBank is responsible for the processing of the financial data of the claimant and is obliged to adopt appropriate measures to ensure their confidentiality, taking into account the greater risk that joint ownership of financial products poses to confidentiality. However, there is no evidence in the proceedings that CaixaBank identified this risk and adopted specific measures for its mitigation, both technical and organizational.

CaixaBank focuses on attributing the facts to a human error by the employee, but the outcome, the realization of the risk, was easily foreseeable, and CaixaBank has not demonstrated the existence of any technical or organizational measures, alerts, or controls aimed at preventing employees from accessing and providing specific data of co-owners to other co-owners who lacked representation in cases of joint ownership. The guarantee of confidentiality requires the application of those resources, procedures, and controls that may be necessary, which is not evidenced to have been carried out in this case.

CaixaBank must ensure that the measures it adopts are effective, and a basic measure is to guarantee that the financial information of a particular client can only be provided to a third party if the client has given their consent and this consent is updated and refers to the specific processing operation that is intended to be carried out.

Moreover, CaixaBank must be accountable for the actions taken on its behalf; the actions of the employee do not exempt the company from liability. The company's liability in the sanctioning field for the actions of an employee that constitute a breach of data protection regulations has been confirmed by the Judgment of the Court of Justice of the European Union, dated December 5, 2023, issued in case C-807/21 (Deutsche Wohnen), which indicates

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
21/35

“24 In effect, according to the aforementioned judicial body, this jurisprudence, like the majority of national doctrine, places special importance on the concept of "undertaking," in the sense of Articles 101 TFEU and 102 TFEU, and, therefore, on the idea that responsibility is attributed to the economic entity in which the undesirable behavior has been adopted, for example, behavior contrary to competition. In its view, according to this "functional" conception, all acts of all employees authorized to act on behalf of a company are attributable to the company, even within the framework of an administrative procedure.

(...)

44 Regarding legal entities, this implies, on the one hand, as essentially pointed out by the Advocate General in points 57 to 59 of his conclusions, that they are responsible not only for the infringements committed by their representatives, directors, or managers, but also for any other person acting within the scope of the business activity of those legal entities and on their behalf. On the other hand, the administrative fines provided for in Article 83 of the GDPR in the event of such infringements must be able to be imposed directly on legal entities when they can be classified as responsible for the processing in question.”

Also by the jurisprudence of the Supreme Court. In this regard, it should be noted that the Judgment of the Supreme Court No. 188/2022 (Contentious Chamber, Section 3), of February 15, 2022 (rec. 7359/2020), mentioned by BBVA in its written allegations to the initiation agreement; states in its Fourth Legal Ground: “The fact that it was the negligent action of an employee does not exempt her from her responsibility as the person in charge of the correct use of the security measures that should have guaranteed the proper use of the designed data registration system. As we already stated in STS No. 196/2020, of February 15, 2021 (rec. 1916/2020), the data processor is also responsible for the actions of its employees and cannot excuse itself based on its diligent action, separately from the actions of its employees, but rather it is the "culpable" actions of these, resulting from the violation of existing security measures, that underpin the company's responsibility in the sanctioning field for "own" acts of its employees or officials, not of third parties.”

The judgment continues arguing about the responsibility of legal entities: “...It simply happens that, while direct responsibility of legal entities is admitted in our Administrative Law, to which they are therefore recognized as having infringing capacity, the subjective element of the infringement is manifested in these cases differently than it is for natural persons, so that, as the constitutional doctrine we have previously mentioned indicates - STC 246/1991, of December 19 (F.J. 2) and 129/2003, of June 30 (F.J. 8) - direct reproachability derives from the legal good protected by the norm that is infringed and the need for that protection to be truly effective and from the risk that, consequently, the legal entity subject to compliance with that norm must assume.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

22/35

That said, from what has been presented by CAIXA, it is clearly deduced that it is necessary not only

to have a regulatory framework and a training and awareness program for its employees, as the responding party states, but also to reiterate that other measures are necessary to help reduce the specific risks arising from the specific characteristics of the processing. Furthermore, it is necessary to adapt over time the application and validity of that regulatory framework and to implement continuous training in data protection, which ensures employee awareness of the confidentiality of personal and financial information of their clients.

For all these reasons and given what has occurred, it is easy to assess that the technical and organizational measures adopted were not appropriate to guarantee a level of security adequate to the risk presented by data processing; moreover, we must insist on the fact that if appropriate technical and organizational preventive measures have been adopted with the aim of avoiding incidents like the one that occurred, it is because the security measures implemented were insufficient or not robust enough.

Finally, and in reference to what has been presented, it is necessary to note the judgment of the AN of February 9, 2023 (rec. 770/2022) which states:

“(…) The security measures implemented subsequently do not affect the commission of the infringement (…).”

SECOND. - APPLICATION OF THE PRINCIPLE “NON BIS IN IDEM”: THE AGENCY IS SANCTIONING TWICE FOR THE SAME PUNISHABLE ACT.

The entity states the following:

We refer to the Proposal for Resolution of this Agency, in which it indicates the following:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
23/35

As can be observed, the AEPD states that, “understood broadly,” there is no violation of the principle NON BIS IN IDEM, avoiding mentioning and focusing on what is evident: that the alleged lack of technical and organizational measures aimed at ensuring data security to prevent an event like the one that occurred is the conduct subject to double sanction, without us being able to understand the Agency's digressions on this matter, since, as indicated by the Judgment of the High Court that it itself cites, it is obvious that the triple identity between the compared terms exists:

- (i) The data controller is Caixabank in both alleged infringements
- (ii) The conduct is the same: alleged lack of technical or organizational measures, presumably not appropriate to prevent situations like the one that occurred
- (iii) The same conduct is subject to a double punitive sanction by this Agency

Therefore, from a simple analysis and not from a “broad understanding,” it results that the identity of terms leading to the flagrant violation of the principle NON BIS IN IDEM does indeed exist in the present administrative sanctioning activity.

And again, the European Court, in the recent Judgment already cited, supports the argument of this party, as it confines the principle of responsibility of the data controller to the appropriateness of the technical or organizational measures adopted by it, aimed at ensuring that the data is processed with adequate security, and therefore, that the processing is carried out in accordance with the GDPR:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

24/35

“49 In this regard, it should be recalled, firstly, that Article 5, paragraph 2, of the GDPR establishes a principle of accountability under which the data controller is responsible for compliance with the

principles relating to the processing of personal data set out in paragraph 1 of this article and stipulates that this controller must be able to demonstrate compliance with those principles.

50 In particular, the data controller must, in accordance with the principles of integrity and confidentiality of personal data established in Article 5, paragraph 1, letter f), of that Regulation, ensure that such data is processed in such a way as to guarantee an adequate level of security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, through the application of appropriate technical or organizational measures and must be able to demonstrate compliance with the aforementioned principles.

51 It should also be noted that both Article 24, paragraph 1, of the GDPR, in relation to Recital 74 thereof, and Article 32, paragraph 1, of the same Regulation require the data controller, for all processing of personal data carried out by it or on its behalf, to implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is in compliance with the Regulation.”

In response to this allegation and without intending to reiterate what has already been addressed regarding the allegations in the initiation agreement, this Agency must insist that there is no violation of the principle non bis in idem.

The fact that the ex-husband of the claimant was provided with tax information from the year 2021 regarding all products of Caixabank, of which she was the holder, without her prior consent evidences a violation of Article 5.1.f) of the GDPR. Since it has not been demonstrated that appropriate technical and organizational measures of all kinds were adopted to ensure confidentiality in jointly held products. Moreover, it is evident that the security measures, solely security measures, implemented by CAIXA were not effective as they did not prevent or reduce the likelihood of the risk materializing due to negligent actions by an employee, and therefore it must be concluded that it did not have appropriate security measures based on the possible estimated risks, violating what is provided in Article 32 “Security of processing” of the GDPR.

Well, we must bring to attention what was stated in the previous section regarding the difference between the violation of Article 5.1.f) and Article 32 of the GDPR, the different typification in different paragraphs of Article 83 of the GDPR, and the different qualification of both for the purposes of prescription in the LOPDGDD.

Likewise, as we indicated, Article 5.1.f) of the GDPR is violated when there is a loss of confidentiality, integrity, or availability of the data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
25/35

personal, which may or may not occur due to the absence or deficiency of security measures.

This principle merely determines the channel through which the maintenance of confidentiality, integrity, or availability can be achieved when it explicitly states "through the application of appropriate technical and organizational measures," which are not strictly security measures.

CAIXA states that the appropriate technical and organizational measures referred to in this provision are the security measures of Article 32 of the GDPR. This would simplify the essence of the GDPR, whose compliance is not limited to the implementation of technical and organizational security measures; it would mean, in our case, reducing the guarantee required by the principle of integrity and confidentiality to its achievement solely with security measures.

As we have pointed out previously, when Article 5.1(f) of the GDPR refers to appropriate technical or organizational measures to guarantee the rights and freedoms of data subjects within the framework of compliance management of the GDPR, it does so in the sense provided in Article 25 of the GDPR regarding privacy by design.

This provision states that,

"Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity that the processing poses to the rights and freedoms of natural persons, the data controller shall implement,

both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to meet the requirements of this Regulation and protect the rights of data subjects” (the underlining is from this Agency).

We reiterate that there are multiple technical or organizational measures that are not security measures and that the data controller can implement as a means to guarantee this principle.

However, Article 32 of the GDPR includes the obligation to implement appropriate technical and organizational security measures to ensure a level of security appropriate to the risk. Security measures. Only security measures.

Furthermore, its objective is to ensure a level of security appropriate to the risk, while in the case of Article 5.1(f) of the GDPR, confidentiality and integrity must be guaranteed. As can be seen, the two articles pursue different purposes, although they may be related.

It is evident that if the security measures implemented by CAIXA were not reasonable based on the estimated potential risks and were detected by the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/35

AEPD, without the loss of confidentiality and availability having occurred, would only have been sanctioned under Article 32 of the GDPR.

CAIXA considers that both provisions require a single conduct, which is to implement adequate security; however, it is evident that these are distinct behaviors with different foundations.

THIRD. - AGENCY'S OWN INTERPRETATION OF THE OBLIGATIONS OF MEANS AND THE OBLIGATIONS OF RESULT

CAIXA continues to state:

In its written allegations, the Agency partially agrees with my represented party that the obligations regarding the technical and organizational measures adopted constitute an obligation of means and not of result, which the data controller must strive to achieve through the development of diligent conduct, consisting of the deployment and implementation of appropriate measures. As stated by the Court of Justice of the European Union in its already reiterated Judgment (in the final declarative section): “an unauthorized communication of personal data or unauthorized access to such data by third parties (...) is not sufficient, on its own, to consider that the technical and organizational measures adopted by the data controller in question were not ‘appropriate’ under the aforementioned Articles 24 and 32.”

The surprising fact is that the obligation of means is inferred, according to this Agency, from Article 32 GDPR but not from Article 5.1.f) GDPR. It is very surprising, considering that the principle invoked and allegedly infringed is linked to the “application of appropriate technical or organizational measures.”

This is why we cannot understand how this particular (and peculiar) interpretation of this Agency aligns with the interpretation of the CJEU, in the Judgment that we have repeatedly mentioned and transcribed, nor with the GDPR itself: the data controller is subject to a data protection obligation, and compliance with that obligation involves the adoption of appropriate technical or organizational measures aimed at ensuring such compliance. And this adoption of suitable measures in relation to the potential risks of processing is, in all cases, an obligation of means, never of result, since an unauthorized communication does not constitute an infringement by itself, but rather the possible infringement arises from the assessment of the appropriateness of the measures adopted by the controller, once the risks have been evaluated according to the nature, scope, context, and purposes of the processing. We insist that it is clearly a legal obligation of means and not of result:

“38 (...) Recital 83 of the GDPR, which states, in its first sentence, that ‘in order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor

must assess the inherent risks of processing and implement measures to mitigate them.' From this

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
27/35

In this way, the Union legislator expressed its intention to "mitigate" the risks of violating the security of personal data, without intending to eliminate them."

In response to the allegations, this Agency refers to what has already been argued regarding the difference between obligations of means and obligations of result.

Caixabank, in its argumentation, seems to seek confusion between the attribution of Article 5.1.f) and the attribution of Article 32 of the GDPR; however, as has already been made clear previously, these are distinct violations, different provisions with different classifications in the GDPR and different qualifications for the purposes of prescription in the LOPDGDD.

FOURTH. - ON THE APPLICATION OF AGGRAVATING CIRCUMSTANCES

CAIXA indicates:

In the present Sanctioning Procedure, this Agency considers that the following aggravating circumstances are present:

"Sanction for the violation of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the violation in question is serious for the purposes of the GDPR and that it is appropriate to graduate the sanction to be imposed according to the following criteria established by Article 83.2 of the GDPR:

As aggravating factors:

- b) the intentionality or negligence in the violation;"

"Sanction for the violation of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the violation in question is serious for the purposes of the GDPR and that it is appropriate to graduate the sanction to be imposed according to the following criteria established by Article 83.2 of the GDPR:

As aggravating factors:

- b) the intentionality or negligence in the violation;"

We must reiterate that my client considers that in this case there is no violation of Article 5.1.f) GDPR or Article 32 GDPR, and, in light of the technical and organizational measures that CaixaBank has implemented (detailed in our previous written submissions and reiterated again in this document), to prevent data processing operations contrary to the GDPR, labeling the incident as "intentional or negligent violation" by the Agency is, evidently, subjectively disproportionate and in no case in accordance with the law.

In response to the allegations and since this Agency considers that there is indeed a violation of Article 5.1.f) GDPR and a violation of Article 32 GDPR, for this purpose,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
28/35

It is necessary to refer to what was invoked by the Judgment of the Court of Justice of the European Union, dated December 5, 2023, in the case C-807/21 (Deutsche Wohnen), which states:

"76 In this regard, it should also be specified, concerning the question of whether an infringement has been committed intentionally or negligently and, therefore, may be sanctioned with an administrative fine under Article 83 of the GDPR, that a data controller may be sanctioned for behavior falling within

the scope of the GDPR when they could not ignore the infringing nature of their conduct, whether or not they were aware of infringing the provisions of the GDPR (see, by analogy, the judgments of June 18, 2013, Schenker & Co. and others, C-681/11, EU:C:2013:404, paragraph 37 and cited case law; of March 25, 2021, Lundbeck/Commission, C-591/16 P, EU:C:2021:243, paragraph 156, and of March 25, 2021, Arrow Group and Arrow Generics/Commission, C-601/16 P, EU:C:2021:244, paragraph 97).” (the underlining is ours).

In the same vein, the judicial bodies of our country express themselves. Thus, the Judgment of the National Court, dated January 21, 2010, states:

“The appellant also maintains that there is no culpability in their actions. It is true that the principle of culpability prevents the admission in administrative sanctioning law of objective responsibility; it is also true that the absence of intent is secondary since this type of infringement is normally committed through culpable or negligent conduct, which is sufficient to integrate the subjective element of fault. The conduct of XXX is clearly negligent since... they must know... the obligations imposed by the LOPD on all those who handle personal data of third parties. XXX is obliged to guarantee the fundamental right to the protection of personal data of their clients and hypothetical clients with the intensity required by the content of the right itself.”

The Supreme Court (Judgments of April 16 and 22, 1991) considers that from the culpability element it follows that “...the action or omission, qualified as an administratively sanctionable infringement, must be, in any case, attributable to its author, whether by intent or negligence, imprudence, or inexcusable ignorance.” The same Court reasons that “it is not enough... for exculpation against a typically unlawful behavior to invoke the absence of fault” but it is necessary “that the diligence required by the one alleging its non-existence has been employed” (STS January 23, 1998).

Also connected with the degree of diligence that the data controller is obliged to exercise in complying with the obligations imposed by data protection regulations is the Judgment of the National Court of October 17, 2007 (Rec. 63/2006), which specified: “(...) the Supreme Court has understood that there is imprudence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the diligence required.”

Furthermore, the National Court in matters of personal data protection has declared that “simple negligence or non-compliance with the duties that the Law imposes on the persons responsible for files or the...

29/35

data processing to exercise utmost diligence...” (Judgment of the National Court of June 29, 2001). For all the reasons stated, the allegations presented are DISMISSED.

III

Article 5.1.f) of the GDPR

Article 5.1.f) “Principles relating to processing” of the GDPR states:

“1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures (‘integrity and confidentiality’).”

In this case, it is established that the personal data of the claimant, contained in CAIXA's database, was improperly disclosed to third parties, violating the principle of confidentiality; as the fiscal information for 2021 of all the products of Caixabank, of which the claimant was the holder, was provided to her ex-husband, who later handed over this documentation to their daughter.

CAIXA admits that the events that occurred, the delivery of the Unique Tax Certificate to the claimant's ex-husband, were the result of a human and unintentional error by the staff providing services at the office.

It is considered that the known facts constitute an infringement, attributable to CAIXA, for violating Article 5.1.f) of the GDPR.

IV

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to up to 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 72 “Infringements considered very serious” of the LOPDGDD indicates:

“1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following shall be considered very serious and shall be subject to a limitation period of three years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)”

V

Sanction for the infringement of Article 5.1.f) of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is considered that the infringement in question is serious for the purposes of the GDPR and that it is appropriate to adjust the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- b) the intentionality or negligence in the infringement;

CAIXA informs this Agency regarding the reported facts that there has been “... a human and unintentional error in the delivery of the Unique Tax Certificate to the ex-husband of the Claimant...”

However, the facts revealed in this case demonstrate a clear lack of diligence in the actions of its employee.

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be particularly weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on rigor and exquisite care to comply with the legal provisions in this regard. [Judgment of the National Court of 10/17/2007 (rec. 63/2006)]

As aggravating factors:

- b) The connection of the infringer's activity with the processing of personal data.

CAIXA, in the exercise of its financial activity, must provide, personally or through accredited representation, all its clients with the fiscal information they require in the exercise of their tax obligations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/35

As a result, and for the purpose of complying with the legally established requirements, the exercise of this activity necessarily implies knowledge and application of the current regulations regarding personal data protection.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, with respect to the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, allows for the imposition of a fine of €50,000 (FIFTY THOUSAND EUROS).

VI

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular account shall be taken of the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless he or she is required to do so by Union or Member State law."

In the present case, at the time of the personal data breach, there is no record that CAIXA had reasonable security measures in place based on the estimated potential risks.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

32/35

CAIXA states that "...in the context of the indistinct management of the product shared by the marriage formed by the Claimant and Mr. B.B.B., who acted as the interlocutor before the office (and who, according to the Claimant, is now her ex-spouse), the office accessed all the tax information of both holders, incurring in a human and involuntary error in delivering the Unique Tax Certificate to the Claimant's ex-husband..."

However, the incident highlights a clear lack of diligence on the part of the employee and the absence of adequate measures to prevent such actions by employees.

Furthermore, the existence of joint ownership in CAIXA's financial products entails a certain risk that errors like this may occur.

The delivery of personal documentation corresponding to the tax information of Caixabank products to a person other than the holder, without the authorization and consent of the holder, evidences a deficiency in the implementation of measures appropriate to the risk or a breach of the existing ones. It is considered that the known facts constitute an infringement, attributable to CAIXA, for violating Article 32 of the GDPR.

VII

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for

the imposition of administrative fines” provides:

“Infringements of the following provisions shall be subject to administrative fines of up to €10,000,000 or, in the case of an undertaking, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following shall be considered serious and shall be subject to a two-year limitation period: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/35

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.”

VIII

Sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, it is considered that the infringement in question is serious for the purposes of the GDPR and that it is appropriate to gradate the sanction to be imposed in accordance with the following criteria established by Article 83.2 of the GDPR:

As aggravating factors:

-

b) The intentionality or negligence in the infringement;

CAIXA informs this Agency regarding the reported facts that there has been “... a human and involuntary error in the delivery of the Single Tax Certificate to the ex-husband of the Claimant...”

In this same sense, the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard. [Judgment of the National Court of 17/10/2007 (rec. 63/2006)]

As aggravating factors:

-

b) The connection of the infringer's activity with the processing of personal data.

CAIXA, in the exercise of its financial activity, must provide all its clients with the tax information they require in the exercise of their tax obligations.

Consequently, and for the purpose of complying with the legally established requirements, the exercise of this activity necessarily implies knowledge and application of the current regulations on personal data protection.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for the imposition of a sanction of €20,000 (TWENTY THOUSAND EUROS).

IV

Adoption of measures

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

34/35

The text of the resolution establishes what the infringements committed have been and the facts that have led to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them correspond to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

In light of the above, the following is issued:

Therefore, in accordance with the applicable legislation and having assessed the criteria for the gradation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on CAIXABANK, S.A., with NIF A08663619, for an infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR, respectively, a fine of:

- For the infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of that regulation, an administrative fine of €50,000 (FIFTY THOUSAND EUROS)
- For the infringement of Article 32 of the GDPR, classified under Article 83.4.a) of that regulation, an administrative fine of €20,000 (TWENTY THOUSAND EUROS).

SECOND: NOTIFY this resolution to CAIXABANK, S.A.

THIRD: This resolution will be executive once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right.

The sanctioned party is warned that it must pay the imposed sanction once this resolution becomes executive, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, in the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is executive, if the date of executiveness falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

35/35

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file

an administrative contentious appeal before the Administrative Litigation Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Litigation Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es